

ADENDA DE ACTUALIZACIÓN NORMATIVA

Módulo: Normativa de Ciberseguridad – Unidad 5

Normativa vigente de ciberseguridad de ámbito nacional e internacional

1. Actualización de Estándares Internacionales

A. ISO/IEC 27001:2022 (sustituye a la versión 2013)

El temario original hace referencia a la estructura de la norma de 2013. En octubre de 2022 se publicó la nueva versión. El cambio más drástico se encuentra en el **Anexo A** (la lista de controles de seguridad).

Característica	Versión Antigua (2013)	Versión Actual (2022)
Número de Controles	114 controles.	93 controles (se han fusionado y simplificado).
Organización	14 Dominios (ej. RRHH, Físico, Criptografía...).	4 Temas (Themes).
Nuevos Controles	N/A	Se introducen 11 nuevos controles, incluyendo <i>Inteligencia de Amenazas</i> , <i>Seguridad en la Nube</i> y <i>Seguridad en el Desarrollo</i> .

Los 4 nuevos temas de controles:

1. **Organizacionales:** 37 controles (políticas, roles, inteligencia de amenazas...).
2. **Personas:** 8 controles (trabajo remoto, concienciación, confidencialidad...).
3. **Físicos:** 14 controles (seguridad de oficinas, mantenimiento, monitoreo...).
4. **Tecnológicos:** 34 controles (autenticación, malware, redes, cifrado...).

B. NIST Cybersecurity Framework 2.0 (sustituye a la v1.1)

El material original muestra el gráfico de la versión 1.1 con 5 funciones. A principios de 2024, el NIST lanzó la versión 2.0, que cambia el núcleo del marco.

El cambio principal es que ya no son 5 funciones, sino 6. Se añade la función de **Gobernanza** como un círculo central que influye en todas las demás.

- **GV (Govern):** La estrategia de ciberseguridad, las expectativas y la política son establecidas, comunicadas y monitoreadas por la alta dirección.

- **IP (Identify) - PR (Protect) - DE (Detect) - RS (Respond) - RC (Recover):** Se mantienen, pero subordinadas a la gobernanza.

Cambio de Alcance:

- **Antes:** Enfocado principalmente en infraestructuras críticas.
- **Ahora:** Diseñado explícitamente para cualquier organización, independientemente de su tamaño o sector.

2. Actualización de Normativa Europea

A. Directiva NIS 2 (sustituye a la Directiva NIS 1)

El material original explicaba la Directiva NIS de 2016. Esta ha sido derogada por la **Directiva (UE) 2022/2555**, conocida como **NIS 2**.

Principales Novedades:

1. **Ampliación de Sectores:** Ya no se distingue solo entre "Operadores de Servicios Esenciales" y "Proveedores de Servicios Digitales". Ahora se clasifican en:
 - **Entidades Esenciales:** Energía, transporte, banca, salud, agua, administración pública, espacio.
 - **Entidades Importantes:** Correos, gestión de residuos, química, alimentación, industria manufacturera, proveedores digitales.
2. **Responsabilidad de la Dirección:** Los directivos pueden ser **personalmente responsables** si no aseguran el cumplimiento de las medidas de ciberseguridad (incluyendo inhabilitación temporal en casos graves).
3. **Régimen Sancionador:** Multas mucho más elevadas (hasta el 2% del volumen de negocio global anual para entidades esenciales).
4. **Cadena de Suministro:** Obligación de gestionar los riesgos de seguridad de los proveedores directos.

B. Directiva CER (sustituye a la Directiva de Infraestructuras Críticas 2008)

El material mencionaba la Directiva 2008/114/CE. Esta ha sido sustituida por la **Directiva (UE) 2022/2557 (Directiva CER)** sobre la resiliencia de las entidades críticas.

- Mientras que la NIS 2 se ocupa de la **ciberseguridad**, la Directiva CER se ocupa de la **seguridad física y la resiliencia** ante amenazas no cibernéticas (desastres naturales, terrorismo físico, sabotaje).
- Ambas directivas están alineadas para garantizar una protección integral (física + lógica).